CineTrack — Derinlemesine Kod İnceleme ve Düzeltme Spesifikasyonu

İncelenen repo: `6yildiz9-maker/cinetrack` (commit `c8b350a`, ana dal) **İnceleme kapsamı:** Sunucu (`server.ts`, `src/server/*`), çekirdek katman (`src/core/*`), istemci (`src/App.tsx`, `src/components/*`, `src/services/*`, `src/hooks/*`), yapılandırma (`vite.config.ts`, `tsconfig.json`, `eslint.config.js`, `ci.yml`), testler. **Toplam incelenen kaynak:** ~22.000 satır TypeScript/TSX (44 dosya), 6 test dosyası, CI hattı.

---

0. Yönetici Özeti

CineTrack, kişisel film/dizi takibi için tasarlanmış, React 19 + Vite 8 + Express 5 tabanlı bir PWA. Kod kalitesi **beklenenin üzerinde**: atomik JSON yazma (fsync + rename + karantina + kurtarma), ETag/revizyon tabanlı iyimser eşzamanlılık, toplu veri kaybı koruması (`sudden_item_drop`), GitHub senkronunda okuma-geri-doğrulama (SHA-256), açık depoya kişisel veri yazma onayı, `redactSecrets` ile sır maskeleme ve kapsamlı birim testleri mevcut.

Buna karşılık **1 kritik güvenlik açığı** (varsayılan ağ bağlanabilirliği + kimlik doğrulamasız API), **3 yüksek öncelikli risk** (Node sürüm uyumluluğu, çevrimdışı kuyrukta sessiz veri kaybı, bloklayan senkron dosya işlemleri) ve bir dizi orta/düşük öncelikli sorun tespit edildi. Ayrıca devasa dosya boyutları ciddi bir sürdürülebilirlik riski oluşturuyor.

Öncelik matrisi: P0 = hemen (güvenlik/veri kaybı), P1 = bu sprint, P2 = kademeli teknik borç.

> **Entegrasyon notu:** Bu spec, kullanıcı tarafından sağlanan beş ayrı yapay zekâ incelemesinin (ChatGPT, Gemini, DeepSeek, Kimi, Perplexity) bulgularıyla zenginleştirilmiştir. Her iddia, bu incelemede kullanılan repo aynasında (commit `c8b350a`) satır satır yeniden doğrulanmıştır; yalnızca kanıtla desteklenenler **EXT-01…EXT-14** numarasıyla Bölüm 6'da yer alır, çürütülen veya doğrulanamayan iddialar ise Bölüm 6.3'te ayrıca listelenir. Mevcut BUG-xx bulgularını teyit eden dış incelemeler Bölüm 6.1'deki eşleme tablosunda gösterilir.

---

1. P0 — Kritik

BUG-01 · Varsayılan `0.0.0.0` bağlantısı + opsiyonel token = LAN'a açık kişisel veri

- **Kanıt:** `server.ts` → `const host = process.env.CINETRACK_HOST || process.env.HOST || '0.0.0.0';` (satır ~24). `src/server/security.ts` → `createTokenAuthMiddleware` token **yoksa** doğrudan `next()` yapar (no-op) ve `requireTokenForReads` varsayılan `false`'tur. `GET /api/data`, `/api/catalog`, `/api/sync/status` guard'sız.
- **Sorun:** Sunucu ağ arayüzlerinin tamamında dinler. `CINETRACK_TOKEN` ayarlanmadıysa (varsayılan kurulumda ayarlanmaz; `.env.example`'da bile yok) aynı ağdaki **herhangi bir cihaz**: (a) tüm izleme geçmişini/profilleri okuyabilir (`GET /api/data`), (b) veriyi değiştirebilir (`PUT /api/data` — Origin

guard'ı `Origin` başlığı göndermeyen istemcileri zaten geçiriyor, yani `curl` için hiçbir engel yok), (c) sunucudaki PAT ile GitHub senkronunu tetikleyebilir (`POST /api/sync/*`).

- **Ayrıca:** `server.ts` içindeki `const CINETRACK_HOST = '127.0.0.1'; void CINETRACK_HOST;` ölü/yanıltıcı koddur — sanki varsayılan loopback'i izleniyor gibi görünmesine rağmen gerçek host `0.0.0.0`'dır.
- **Çözüm:**
  1. Varsayılan host'u `127.0.0.1` yapın: `const host = process.env.CINETRACK_HOST || process.env.HOST || '127.0.0.1';` Harici erişim isteyen kullanıcı `CINETRACK_HOST=0.0.0.0`'ı açıkça seçsin.
  2. Harici arayüze bağlanırken (`host !== '127.0.0.1' && host !== 'localhost'`) ve `CINETRACK_TOKEN` boşsa: startup'ta **kırmızı uyarı** basın ve tüm `/api/data` + `/api/sync/*` mutasyonlarını `503 auth_required` ile reddedin ("yerel erişim serbest, uzak erişim için token zorunlu").
  3. `.env.example` içine `CINETRACK_TOKEN=degistirin-bir-sifre` satırı ekleyin; ilk çalıştırmada token yoksa rastgele bir token üretip `.env.local`'a önerin.
  4. Ölü `CINETRACK_HOST`/`void` satırlarını silin.
- **Kabul kriteri:** Token yokken `0.0.0.0` modunda `PUT /api/data` 503 döner; loopback'te mevcut davranış bozulmaz; README'de "Uzaktan erişim" bölümü belirtilir.

BUG-02 · Çevrimdışı kuyrukta sessiz veri kaybı (localStorage kota aşımı)

- **Kanıt:** `src/services/offline-queue.ts` → `enqueueOfflineSyncSnapshot` içinde `localStorage.setItem(...)` boş `catch {}` ile yutulur ve fonksiyon hâlâ `entry` döner. `src/hooks/useOfflineSync.ts` ise bu durumda `pendingSync = true` yapar.
- **Sorun:** Sunucu kapalıyken bile `serverSyncReady`'in `.finally()`'ı ile (`App.tsx` ~satır 504) debounced push çalışır; ağ hatasında (`status 0`) tam `DataDocument` localStorage'a kuyruklanır. Uygulama limiti 25 MiB (`limits.ts`) iken tarayıcı localStorage kotası tipik olarak 5–10 MiB'dir. Kota aşılırsa yazma **sessizce** başarısız olur, arayüz "kuyrukta" gösterir, sekme kapanınca değişiklikler kaybolur. (Karşıt olarak `cinetrack-core.ts` `savePersistentTasteMap` aynı senaryoda compaction + in-memory fallback yapıyor — kuyrukta bu disiplin yok.)
- **Çözüm:**
  1. `enqueueOfflineSyncSnapshot` dönüş tipini `{ entry, persisted: boolean }` yapın; `setItem` başarısızlığında `persisted: false` döndürün.
  2. `useOfflineSync.syncDocument` persisted=false ise kullanıcıya açık uyarı gösterin: "Değişiklikler yalnızca bu sekmede duruyor — sunucu dönene kadar sekmeyi kapatmayın."
  3. Orta vade: kuyruk depolamasını IndexedDB'ye taşıyın (`relationship-cache.ts`'te zaten benzer bir kalıp var) veya payload'u kompakt forma indirin (özet + items).
  4. Regresyon testi: `enqueueOfflineSyncSnapshot`'ı mocked-quota localStorage ile çağırıp `persisted === false` ve UI uyarısını doğrulayın.

---

2. P1 — Yüksek

BUG-03 · `node server.ts` sessizce Node sürümüne bağlı (engines kilidi yok)

- **Kanıt:** `package.json` → `"start": "node server.ts"`, `engines` alanı yok. Kod, Node'un yerel TypeScript type-stripping'ine dayanır (Node 22.18+/23.6+ varsayılan; eski sürümlerde derleme hatasıyla çöker). CI `node-version: '22'` kullanır — bu bugün ≥22.18'e çözüldüğü için yeşil görünüyor, ancak yerelde Node 20 veya 22.6–22.17 kullanan biri için `npm start` doğrudan syntax error verir. `tsx` ile `dev` çalışır ama prod için `tsx` devDependency olduğu için `npm prune --omit=dev` sonrası yoktur.
- **Çözüm:**
  1. `package.json`'a ekleyin: `"engines": { "node": ">=22.18.0" }` ve `start.bat` içinde sürüm denetimi (baştaki `where node` bloğunun yanına `node -e "const [ma,mi]=process.versions.node.split('.').map(Number); if(ma<22||(ma===22&&mi<18)){console.error('Node >= 22.18 gerekir');process.exit(1)}"`).
  2. `tsconfig.json`'a `"erasableSyntaxOnly": true` ekleyin (TS 5.8+): enum/namespace/constructor param-prop gelecekte eklenirse tsc anında yakalar; Node type-stripping uyumluluğu kalıcı garantiye bağlanır. (Kod şu an incelendi: erasable-olmayan sözdizimi yok, yani bu güvenli.)
  3. README kurulum bölümüne "Node.js ≥ 22.18" şartını yazın.
- **Kabul kriteri:** Node 22.17 Docker imajında `npm start` açık hata verir (engines), CI lint'i `erasableSyntaxOnly` ile geçer.

BUG-04 · Senkron (bloklayan) dosya I/O — request handler içinde

- **Kanıt:** `src/server/storage.ts` (`readFileSync`/`writeFileSync`/`copyFileSync`), `src/server/app.ts` (`readFileSync` yedek indirmede, satır ~830), `excel-profile-backup.ts` (`writeFileSync` ~satır 2778). Ana veri dosyası 25 MiB'e kadar büyüyebilir.
- **Sorun:** 25 MiB JSON'un senkron parse+stringify+write+fsync'i event loop'u yüzlerce ms–sn bloklar; bu sürede TMDB proxy, diğer istemciler ve PWA istekleri donar. Tek kullanıcılı kurulumda küçük, ama 5 dk'lık otomatik sync + debounced istemci push'u üst üste bindiğinde hissedilir gecikmeler üretir.
- **Çözüm (kademeli):**
  1. Kısa vade: `readJsonFileWithRecovery` ve `writeJsonFileAtomic`'i `fs/promises` tabanlı asenkron varyantlara geçirin; `FileWriteSerializer` zaten sıraya alıyor, bu taşıma güvenli.
  2. Yedek indirme endpoint'inde `readFileSync` yerine `createReadStream` + `res.stream` kullanın.
  3. Excel dışa aktarımında `writeFileSync(fullPath, buf)` → `await fs.promises.writeFile(...)`.
- **Kabul kriteri:** 25 MiB veri ile yük altında `/api/health` p99 < 50 ms kalır (basit k6/autocannon ölçümü).

BUG-05 · Rate limiter `X-Forwarded-For`'a güveniyor + varsayılan kapalı

- **Kanıt:** `src/server/security.ts` → `clientIp = forwarded.split(',')[0] || ...`. `createTmdbRateLimitMiddleware` `maxReq <= 0` ise no-op; env/opt belirtilmedikçe devre dışı.
- **Sorun:** (a) Proxy arkasında değilken `X-Forwarded-For` istemci tarafından uydurulabilir → limit her istekte "farklı IP" ile bypass edilir. (b) Açıkta çalışırken (BUG-01 düzeltilse bile) TMDB proxy'si hiçbir rate limite tabi olmaz; sunucudaki TMDB API anahtarı kötüye kullanım vektörüdür.

- **Çözüm:** 1) Uzaktan erişim açıkken (`host !== loopback`) varsayılan rate limit'i etkinleştirin (ör. 60 istek/dk). 2) `X-Forwarded-For`'u yalnızca açık `CINETRACK_TRUST_PROXY=true` bayrağı varsa kullanın; aksi halde `req.socket.remoteAddress`. 3) `app.set('trust proxy', ...)` ayarını belgeleyin.

BUG-06 · Repoya commit'lenmiş build artifact'ları ve ölü metadata

- **Kanıt:** `dev-dist/sw.js` + `dev-dist/workbox-*.js` (vite-plugin-pwa `devOptions.enabled: true` çıktısı — resmi öneri bu klasörün gitignore edilmesi); `.aistudio/` (AI Studio kalıntısı); `metadata.json` → `"MAJOR_CAPABILITY_SERVER_SIDE_GEMINI_API"` (kodda hiçbir Gemini/sunucu-tarafı LLM entegrasyonu yok — grep ile doğrulandı).
- **Sorun:** Depo şişkinliği, gizli tutulması gerekmeyen ama alakasız iç araç kalıntıları, yanlış yönlendiren yetenek bildirimi.
- **Çözüm:** `.gitignore`'a `dev-dist/` ve `.aistudio/` ekleyip repo history'den kaldırın (`git rm -r --cached dev-dist .aistudio`); `metadata.json`'ı silin ya da gerçek yetenekleriyle güncelleyin.

---

3. P2 — Orta / Düşük

BUG-07 · Çevrimdışı kuyrukta 409 çakışmasında kuyruk siliniyor

- **Kanıt:** `src/hooks/useOfflineSync.ts` `flushQueue`: `res.status === 409` → `clearOfflineSyncSnapshot()` sonra `onConflict`.
- **Sorun:** Yerel doküman artık yalnızca React state'inde yaşar. Çakışma banner'ı açıkken sekme kapanırsa, sunucu versiyonuna rağmen yerel değişiklik kalıcı olarak kaybolur (banner yalnızca `serverConflict` state'ini tutuyor; payload korunmuyor).
- **Çözüm:** Çakışma çözülene kadar snapshot'ı kuyrukta tutun; "Yereli koru" başarılı push sonrası, "Sunucuyu kullan" `applyDataDocumentToState` sonrası temizlesin. Ek olarak payload'u `serverConflict` state'ine gömün.

BUG-08 · `resolveExportDocument` istemci snapshot alanlarını kontrolsüz yayıyor

- **Kanıt:** `src/server/app.ts` ~satır 135: `const mergedProfile: Profile = { ...existing, ...snap, ... }`.
- **Sorun:** İstemciden gelen bilinmeyen/rastgele alanlar (`snap`) profile girer; `normalizeDataDocument` sonrasında büyük olasılıkla temizlenir ama sözleşme garantisi yok ve bellekte gereksiz alan birikir.
- **Çözüm:** `snap`'tan yalnızca whitelist'li alanları alın (`name`, `createdAt`, `isDemo`); spread'i kaldırın. Birim testi: bilinmeyen alan içeren snapshot gönderin, kaydedilen profile'da o alanın olmadığını doğrulayın.

BUG-09 · Testler tip denetimi ve lint kapsamı dışında

- **Kanıt:** `tsconfig.json` `include: ["src", "server.ts", "vite.config.ts"]`; `eslint.config.js` `ignores: [... 'tests/**']`.
- **Sorun:** 6 test dosyası (~600 KB) tsc ve eslint'ten geçmez; testlerdeki tip hataları yalnızca çalışma zamanında ortaya çıkar.
- **Çözüm:** Ayrı bir `tsconfig.tests.json` ile `tsc --noEmit -p tsconfig.tests.json` script'i ekleyin; eslint ignores'tan `tests/**`'i çıkarıp (en azından `recommended`) dahil edin. Testler zaten `node:test` + `assert/strict` kalitesinde — buna değiyor.

BUG-10 · i18n yarım implemented (ölü sözlük)

- **Kanıt:** `src/i18n/index.ts` — `setLocale` hiçbir yerden çağrılmıyor (grep: 0 sonuç); `en` sözlüğü ölü. Bileşenlerde yüzlerce hardcoded Türkçe metin.
- **Çözüm:** İkisinden biri: (a) dil seçici ekleyip bileşen metinlerini sözlüğe taşıyın (büyük iş), ya da (b) dürüst davranıp i18n katmanını kaldırın, README'ye "yalnızca TR" yazın. Mevcut ara durum en kötü seçenek: her iki dünyanın bakım maliyeti.

BUG-11 · `any` yoğunluğu ve devasa monolit dosyalar (sürdürülebilirlik)

- **Kanıt:** `cinetrack-core.ts` 5.560 satır / 126+ `any`; `App.tsx` 2.860 satır; `ProfileModal.tsx` 77 KB; `github-bidirectional-sync.ts` 4.489 satır; `tests/core.test.mjs` 198 KB. ESLint'te `no-explicit-any: off`.
- **Sorun:** Merge çakışmaları, code review kalitesi ve yeni katkıda bulunma hızlı düşer; çekirdek dosya hem istemci hem sunucu tarafından import edildiği için her düzenleme iki bundle'ı büyütür.
- **Çözüm (kademeli, davranışı değiştirmeden):**
  1. `cinetrack-core.ts`'i modüllere bölün: `types.ts`, `keys` (zaten var), `normalize.ts`, `taste-profile.ts`, `recommendation.ts`, `taste-map-storage.ts`, `backup-text.ts` (projede zaten `evaluation.ts`, `exporters.ts` gibi parçalar var — aynı yönde devam edin).
  2. `App.tsx`'i: `hooks/useProfiles.ts`, `hooks/useRecommendations.ts`, `hooks/useCatalog.ts`, `hooks/useReminders.ts` şeklinde custom hook'lara bölün; JSX'i sayfa bileşenlerine taşıyın.
  3. `no-explicit-any`'yi `warn`'e alın, yeni PR'lerde `error`'e yükseltin (yeni kod için `tsc` guard'ı).
- **Not:** Bu, tek seferlik büyük refactor değil; "her dokunduğunda dosyayı böl" politikası + ölçüt: hiçbir dosya 1.000 satırı geçmesin.

BUG-12 · Güvenlik başlıkları ve güvenlik odaklı küçük eksikler

- `helmet` benzeri başlık seti yok (`X-Frame-Options`/CSP yok; index.html inline SVG'li SPA). Sertifikasız localhost kullanımında risk düşük ama eklenmesi ucuz: `res.setHeader('X-Frame-Options','DENY')`, `Referrer-Policy`, temel CSP (`default-src 'self'; img-src https://image.tmdb.org; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src https://fonts.gstatic.com`).
- `GET /api/sync/status` token guard'ı yok: uzak repo adı/branş gibi hafif bilgi sızıntısı (BUG-01 düzelince ikincil kalır; yine de guard ekleyin).
- `parseIfMatchRevision`: `If-Match` başlığı yoksa revizyon kontrolü atlanır (last-write-wins). İstemci her zaman gönderiyor, ancak "revizyon zorunluluğu" sunucuda da istenebilir: `PUT /api/data`'da `If-Match` yoksa ve mevcut `revision > 0` ise 428 (`Precondition Required`) dönün — tasarımın kendi güvencesini sunucu tarafına da kilitleyip veri kaybını tamamen engeller.

BUG-13 · Dokümantasyon/UX küçükleri

- `.env.example` eksik anahtarlar: `CINETRACK_TOKEN`, `PORT`, `CINETRACK_TMDB_RATE_LIMIT` (kod destekliyor, örnek dosyada yok).
- `helpers.ts` `calculateItemWatchMinutes`: film için varsayılan 110 dk, dizi için sezonda 10 bölüm tahmini — istatistikler yanıltıcı olabilir; sabitlere koyup README/İstatistik tooltip'inde "tahmini" ibaresi ekleyin.

- `checkReleaseReminders` effect'i `[checkReleaseReminders]`'e bağlı olduğu için her preferences/savedItems değişiminde interval yeniden kurulur; hatırlatma penceresi (3 gün) nadiren atlanabilir. Ref'lerle sadeleştirin.
- Dependeabot/Renovate yapılandırması yok; `npm audit --production`'ı CI'a ekleyin.
- LICENSE MIT olduğu halde README'de lisans bölümü yok.

---

4. Doğrulanan Güçlü Yönler (korunmalı)

- **Atomik kalıcılık zinciri:** `writeJsonFileAtomic` (temp + fsync + rename + validateParsed + yedek kurtarma + karantina) ve `FileWriteSerializer` ile dosya başına yazma kuyruğu.
- **Çakışma güvenliği:** ETag `"rev-N"` / `If-Match` iyimser kilidi + `sudden_item_drop` toplu silme koruması + istemcide `ConflictBanner` akışı.
- **GitHub sync disiplini:** sınıflandırılmış hatalar (auth/rate_limit/conflict), okuma-geri SHA-256 doğrulaması, açık repoya kişisel veri yazma çift onayı (`public-consent`), `redactSecrets` ile log sızıntısı maskeleme.
- **TMDB proxy:** katı path/query whitelist (regex), parametre doğrulama, in-flight dedup + TTL'li önbellek + stale-cache fallback + demo modu.
- **Test disiplini:** ~600 KB davranışsal test (sync, kalıcı depo, Excel yedeği, çekirdek) + CI'da `--omit=dev` sonrası üretim smoke testi — nadir görülür bir pratik.
- **Erişilebilirlik:** `useDialogAccessibility` (focus trap, ESC, odak iadesi), `aria-live` bölgeleri, klavye kısayolları (n, /).

---

5. Uygulama Yol Haritası (önerilen sıra)

1. **Düzeltme seti 1 (P0/P1 güvenlik, ~1 gün):** BUG-01 host/token kilidi + BUG-02 persisted bayrağı + BUG-06 gitignore temizliği + **EXT-09** birleşik config çözümleyici (token gölgeleme — 401 hatasının olası kök nedeni) + **EXT-10** public repoya katalog yazma bloğu.
2. **Düzeltme seti 2 (P1, ~1 gün):** BUG-03 engines + `erasableSyntaxOnly`, BUG-05 trust-proxy rate limit, BUG-07 kuyruk 409 tutma, BUG-12 başlıklar + 428 + **EXT-05** revizyon-0 atlaması (BUG-12'deki 428 önerisiyle aynı PR'da) + **EXT-01** SSRF allowlist + **EXT-06** global JSON error handler + **EXT-07** SPA fallback 404.
3. **Düzeltme seti 3 (P1–P2, ~2 gün):** BUG-04 async I/O geçişi, BUG-08 whitelist, BUG-09 test tip denetimi + **EXT-02** Excel O(n²) düzeltmesi + **EXT-03** poster önbelleği purge + **EXT-04** tek medya türü çözümleyici.
4. **Düzeltme seti 4 (P2, kademeli):** **EXT-08** TMDB upstream sınırı, **EXT-11** silme/tombstone semantiği, **EXT-12** merge boş-alan semantiği, **EXT-13** .env parser sağlamlaştırma, **EXT-14** düşük güvenli UX bulguları.
5. **Sürekli teknik borç (P2):** BUG-11 modülerleştirme politikası, BUG-10 i18n kararı, BUG-13 dokümantasyon küçükleri.

---

6. Diğer Yapay Zekâ İncelemelerinden Entegre Edilen Bulgular (EXT)

Kaynak: Kullanıcının sağladığı inceleme derlemesi (ChatGPT FINDING-01…14, Gemini, DeepSeek, Kimi SEC/RUN/OFF/MER/REV/ERR/API/OPS/DOC-001, Perplexity CT-001…010). **Yöntem:** Her iddia, bu spec'in hazırlanmasında kullanılan repo aynasında (`c8b350a`) grep/sed ile satır düzeyinde yeniden doğrulandı. Yalnızca kaynak kodda kanıtı görülen bulgular aşağıya alındı; doğrulanamayanlar 6.3'te işaretlendi.

6.1 Mevcut BUG'ları teyit eden dış incelemeler

Dış inceleme	Karşılık	Not
ChatGPT FINDING-01, Perplexity CT-002	BUG-01	Her ikisi de `0.0.0.0` + opsiyonel token tespit etti. Ek nüans: token karşılaştırmasında **timing-safe** olmayan string eşitleme kullanıldığı önerisi — `crypto.timingSafeEqual`'a geçirilmesi BUG-01 çözümüne ucuz bir ek.
Kimi OFF-001, Gemini "havuz tükenmesi"	BUG-02	Kimi, localStorage kota sessizce-yutma zincirini bağımsız teyit etti. Gemini'nin "öneri havuzu tükenirse fallback" iddiası ayrı bir çalışma zamanı testi gerektirir (6.3).
Kimi RUN-001	BUG-03	Node type-stripping sürüm kilidi eksikliği bağımsız teyit edildi.
Kimi DOC-001	BUG-06	Repo içi kalıntı/yanıltıcı metadata bulgusu teyit edildi.
DeepSeek "monolit dosyalar", Perplexity CT-008	BUG-11	`App.tsx` / `cinetrack-core.ts` boyut tespitleri teyit edildi; önerilen custom-hook/`useMemo` iyileştirmeleriyle çakışan kısımlar 6.3'te düzeltildi.
ChatGPT FINDING-02	EXT-09 ile birleştirildi	Token önceliği gölgeleme, 401 "Bad credentials" hatasının en olası kök nedeni olarak da değerlendirildi.
Kimi SEC-001	BUG-01	Ağ/erişim güvenliği bulgusu örtüşüyor.

6.2 Yeni doğrulanan bulgular

EXT-01 · SSRF: Excel poster indirme herhangi bir `https://` URL'sini kabul ediyor (P1 — Güvenlik)

- **Kaynak:** ChatGPT FINDING-05 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `src/server/excel-profile-backup.ts` ~satır 696, `resolvePosterUrlForExport`: `poster_path` `https://` ile başlıyorsa veya `poster_url` parse edilebilen herhangi bir `https:` URL'siyse **sorgulanmadan döndürülür**. Alan adı allowlist'i, yönlendirme denetimi yok. Profil verisi ithalatı/snapshot yoluyla kontrol edilen bir URL, sunucunun (TMDB anahtarının ve PAT'ın bulunduğu makinenin) istemci adına istek atmasını sağlayabilir.
- **Kısmi rahatlatma:** İndirme yolunda tek görsel için 5 MiB boyut sınırı + `readImageDimensions` minimum boyut kontrolü var (satır ~790); ancak bu hedef sunucunun varlığını keşfetmeyi ve iç ağ adreslerine deneme yapmayı engellemez.
- **Çözüm:** 1) `image.tmdb.org` (ve varsa `img.tmdb.org` alternatifleri) alan adı allowlist'i; 2) `redirect: 'manual'` ile yönlendirmenin yalnızca allowlist içine yapıldığını doğrula; 3) allowlist dışı URL → yer tutucu poster, hata değil. 4) `poster_path`'in `https://` ile başlamasını kabul etme; yalnızca TMDB path formatı (`/xxxx.jpg`) tanı.
- **Kabul testi:** İthal edilmiş bir kayıtta `https://internal-host:8080/x.jpg` poster_url → istek atılmaz, satır yer tutucu ile dışa aktarılır; test bunu assert eder.

EXT-02 · Excel dışa aktarmada O(n²) kayıt araması (P2 — Performans)

- **Kaynak:** ChatGPT FINDING-07 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `excel-profile-backup.ts` ~satır 1087–1092: `for (const item of normalizedItems)` döngüsü içinde `rawItemsClone.find(r => ... makeMediaKey(...) === key)` — her karşılaştırmada `makeMediaKey` yeniden hesaplanıyor. Profil büyüdükçe dışa aktarma karesel yavaşlar; 20 MB veri + poster indirme ile birlikte katlanır.

- **Çözüm:** Döngüden önce `const rawByKey = new Map(rawItemsClone.map(r => [makeMediaKey(r), r]))` oluştur; gövdede O(1) lookup. `makeMediaKey` çağrı sayısı da ~2n'den n'e iner.
- **Kabul testi:** 5.000 kayıtlık sentetik profil ile dışa aktarma süresi ölçülür; değişiklik öncesi/sonrası karşılaştırma kaydedilir (beklenen: kareelden doğrusala geçiş).

EXT-03 · Poster önbelleği sınırsız büyüyor (P2 — Kaynak kullanımı)

- **Kaynak:** ChatGPT FINDING-10 · **Durum:** Kaynak kodda doğrulandı (grep: purge/LRU/TTL çağrısı yok).
- **Kanıt:** `PosterCacheManager` URL hash'i ile dosya yazıyor; silme, TTL veya toplam boyut sınırı yok. Her yeni/ileri tarihli içerik ve boyut varyantı yeni dosya demek; disk zamanla izinsiz büyür.
- **Çözüm:** 1) Toplam önbellek boyutu üst sınırı (örn. 200 MiB) + LRU purge (atime/mtime tabanlı); 2) TTL (örn. 90 gün); 3) `/api/health` veya tanılama ekranında önbellek boyutu göstergesi.
- **Kabul testi:** Sınır aşıldığında en eski dosyaların silindiği, dışa aktarımın çalışmaya devam ettiği birim testi.

EXT-04 · Medya türü çözümlemesi iki yerde farklı varsayımla yapılıyor (P2 — Veri bütünlüğü)

- **Kaynak:** ChatGPT FINDING-06 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `src/core/keys.ts` satır 9–19 `makeMediaKey`: `media_type !== 'tv'` ise **sessizce 'movie'** varsayar. `src/core/recommendation-orchestrator.ts` satır 88–96 ise bilinmeyen türde `title && !first_air_date` sezgiseliyle **'movie' veya 'tv' tahmin eder**. Aynı belirsiz kayıt, iki katmanda farklı türe çözülebilir → kimlik çakışması (`movie:<id>` vs `tv:<id>`), yanlış öneri havuzu, Excel'de yanlış sekme/etiket.
- **Çözüm:** Tek bir `resolveMediaType(record): 'movie' | 'tv' | 'unknown'` yardımcısı; `unknown` için (a) import'ta reddet/uyar, (b) önericide elemeden önce günlüğe kaydet. `makeMediaKey` tahmin yapmasın; türü bilinmeyen kayıt için `unknown:` önekli geçici anahtar veya hata.
- **Kabul testi:** `media_type` alanı olmayan bir kayıt hem önericide hem Excel'de aynı şekilde (tahmin değil, uyarı) ele alınır.

EXT-05 · Sunucu revizyonu 0 iken çakışma denetimi atlanıyor (P1 — Veri bütünlüğü)

- **Kaynak:** Kimi REV-001 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `src/server/storage.ts` satır 294: revizyon karşılaştırması `currentRevision > 0` koşulunun içinde. Sunucu verisi taze/boşken (rev 0) gelen `If-Match` eski/yanlış revizyon değerleri **kontrol edilmeden** yazılır → yeni kurulumda, istemcinin bayat state'i sessizce sunucunun üzerine yazabilir.
- **Çözüm:** Koşulu kaldırıp her `PUT /api/data`'da `If-Match` zorunlu kılın (BUG-12'deki `428 Precondition Required` önerisiyle aynı düzeltme setinde uygulanır; rev 0 için geçerli ETag `W/"rev-0"` ya da `"rev-0"` formatı netleştirilir).
- **Kabul testi:** Rev 0 sunucuya `If-Match: "rev-999"` ile gönderilen doküman 412 döner.

EXT-06 · Global JSON error handler yok (P2 — Sağlamlık)

- **Kaynak:** Kimi ERR-001 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `src/server/app.ts` — rotalardan sonra kayıtlı son middleware `/api` 404 JSON handler'ı (satır ~843); onun ardından yakalayan bir error-handler middleware yok. Route içinden fırlayan yakalanmamış hata Express'in **varsayılan HTML hata sayfasına** düşer; JSON bekleyen istemci parse hatası alır, kullanıcıya anlamsız bir hata gösterilir.

- **Çözüm:** En sona 4 argümanlı `(err, req, res, next)` error middleware ekleyin: 500 + `{ error: 'internal_error', requestId }`, `redactSecrets` ile mesaj maskelensin, `Content-Type: application/json` garantisi.
- **Kabul testi:** Bilinçli hata fırlatan sahte route ile JSON yanıtı ve status 500 doğrulanır.

EXT-07 · SPA fallback eksik asset'lere de 200 + HTML döndürüyor (P2 — Doğruluk)

- **Kaynak:** Perplexity CT-005 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `server.ts` satır ~149: API olmayan **her** GET `sendFile(indexHtmlPath)` ile yanıtlanır. Var olmayan bir JS/CSS/görsel yolu 404 yerine HTML döndürür → PWA'da bozuk asset sessizce "sayfa içeriği" gibi yüklenir, hata ayıklamayı gizler; `Accept` başlığına bakılmaz.
- **Çözüm:** 1) Path uzantısı statik asset'e benziyorsa (`.js`, `.css`, `.map`, `.png` …) 404 döndür; 2) mümkünse `Accept: text/html` içermeyen navigasyonlara 404. Mevcut davranışın kasıtlı "her yol app'e açılır" tercihi varsa, en azından asset yollarını hariç tutun.
- **Kabul testi:** `GET /nonexistent.js` → 404; `GET /filmler` (SPA yolu) → 200 HTML.

EXT-08 · TMDB upstream yanıtı sınırsız okunuyor + `language` parametresi doğrulanmıyor (P2)

- **Kaynak:** Bu incelemenin ChatGPT/tmdb-proxy bölümlerinden türetilmiş · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** TMDB proxy upstream çağrısında `await upstream.text()` (~satır 602) — `Content-Length` kontrolü ve akış üst sınırı yok; TMDB veya aradaki bir sorunlu yanıt belleği şişirebilir. Query whitelist'inde `language` anahtarı bulunur ancak değer için format kuralı (ISO `xx-XX`) doğrulaması yok.
- **Çözüm:** 1) `Content-Length > 10 MiB` ise reddet + akışı sınırlandır (`upstream.body`'den okurken sayaç); 2) `language` için `^[a-z]{2}(-[A-Z]{2})?--- name: "cinetrack-review-spec" title: "CineTrack Derinlemesine İnceleme ve Hata Düzeltme Spec'i" type: "text/markdown"

CineTrack — Derinlemesine Kod İnceleme ve Düzeltme Spesifikasyonu

İncelenen repo: `6yildiz9-maker/cinetrack` (commit `c8b350a`, ana dal) **İnceleme kapsamı:** Sunucu (`server.ts`, `src/server/*`), çekirdek katman (`src/core/*`), istemci (`src/App.tsx`, `src/components/*`, `src/services/*`, `src/hooks/*`), yapılandırma (`vite.config.ts`, `tsconfig.json`, `eslint.config.js`, `ci.yml`), testler. **Toplam incelenen kaynak:** ~22.000 satır TypeScript/TSX (44 dosya), 6 test dosyası, CI hattı.

---

0. Yönetici Özeti

CineTrack, kişisel film/dizi takibi için tasarlanmış, React 19 + Vite 8 + Express 5 tabanlı bir PWA. Kod kalitesi **beklenenin üzerinde**: atomik JSON yazma (fsync + rename + karantina + kurtarma), ETag/revizyon tabanlı iyimser eşzamanlılık, toplu veri kaybı koruması (`sudden_item_drop`), GitHub senkronunda okuma-geri-doğrulama (SHA-256), açık depoya kişisel veri yazma onayı, `redactSecrets` ile sır maskeleme ve kapsamlı birim testleri mevcut.

Buna karşılık **1 kritik güvenlik açığı** (varsayılan ağ bağlanabilirliği + kimlik doğrulamasız API), **3 yüksek öncelikli risk** (Node sürüm uyumluluğu, çevrimdışı kuyrukta sessiz veri kaybı, bloklayan senkron dosya

işlemleri) ve bir dizi orta/düşük öncelikli sorun tespit edildi. Ayrıca devasa dosya boyutları ciddi bir sürdürülebilirlik riski oluşturuyor.

Öncelik matrisi: P0 = hemen (güvenlik/veri kaybı), P1 = bu sprint, P2 = kademeli teknik borç.

> **Entegrasyon notu:** Bu spec, kullanıcı tarafından sağlanan beş ayrı yapay zekâ incelemesinin (ChatGPT, Gemini, DeepSeek, Kimi, Perplexity) bulgularıyla zenginleştirilmiştir. Her iddia, bu incelemede kullanılan repo aynasında (commit `c8b350a`) satır satır yeniden doğrulanmıştır; yalnızca kanıtla desteklenenler **EXT-01…EXT-14** numarasıyla Bölüm 6'da yer alır, çürütülen veya doğrulanamayan iddialar ise Bölüm 6.3'te ayrıca listelenir. Mevcut BUG-xx bulgularını teyit eden dış incelemeler Bölüm 6.1'deki eşleme tablosunda gösterilir.

---

1. P0 — Kritik

BUG-01 · Varsayılan `0.0.0.0` bağlantısı + opsiyonel token = LAN'a açık kişisel veri

- **Kanıt:** `server.ts` → `const host = process.env.CINETRACK_HOST || process.env.HOST || '0.0.0.0';` (satır ~24). `src/server/security.ts` → `createTokenAuthMiddleware` token **yoksa** doğrudan `next()` yapar (no-op) ve `requireTokenForReads` varsayılan `false`'tur. `GET /api/data`, `/api/catalog`, `/api/sync/status` guard'sız.
- **Sorun:** Sunucu ağ arayüzlerinin tamamında dinler. `CINETRACK_TOKEN` ayarlanmadıysa (varsayılan kurulumda ayarlanmaz; `.env.example`'da bile yok) aynı ağdaki **herhangi bir cihaz**: (a) tüm izleme geçmişini/profilleri okuyabilir (`GET /api/data`), (b) veriyi değiştirebilir (`PUT /api/data` — Origin guard'ı `Origin` başlığı göndermeyen istemcileri zaten geçiriyor, yani `curl` için hiçbir engel yok), (c) sunucudaki PAT ile GitHub senkronunu tetikleyebilir (`POST /api/sync/*`).
- **Ayrıca:** `server.ts` içindeki `const CINETRACK_HOST = '127.0.0.1'; void CINETRACK_HOST;` ölü/yanıltıcı koddur — sanki varsayılan loopback'i izleniyor gibi görünmesine rağmen gerçek host `0.0.0.0`'dır.
- **Çözüm:**
  1. Varsayılan host'u `127.0.0.1` yapın: `const host = process.env.CINETRACK_HOST || process.env.HOST || '127.0.0.1';` Harici erişim isteyen kullanıcı `CINETRACK_HOST=0.0.0.0`'ı açıkça seçsin.
  2. Harici arayüze bağlanırken (`host !== '127.0.0.1' && host !== 'localhost'`) ve `CINETRACK_TOKEN` boşsa: startup'ta **kırmızı uyarı** basın ve tüm `/api/data` + `/api/sync/*` mutasyonlarını `503 auth_required` ile reddedin ("yerel erişim serbest, uzak erişim için token zorunlu").
  3. `.env.example` içine `CINETRACK_TOKEN=degistirin-bir-sifre` satırı ekleyin; ilk çalıştırmada token yoksa rastgele bir token üretip `.env.local`'a önerin.
  4. Ölü `CINETRACK_HOST`/`void` satırlarını silin.
- **Kabul kriteri:** Token yokken `0.0.0.0` modunda `PUT /api/data` 503 döner; loopback'te mevcut davranış bozulmaz; README'de "Uzaktan erişim" bölümü belirtilir.

BUG-02 · Çevrimdışı kuyrukta sessiz veri kaybı (localStorage kota aşımı)

- **Kanıt:** `src/services/offline-queue.ts` → `enqueueOfflineSyncSnapshot` içinde `localStorage.setItem(...)` boş `catch {}` ile yutulur ve fonksiyon hâlâ `entry` döner. `src/hooks/useOfflineSync.ts` ise bu durumda `pendingSync = true` yapar.
- **Sorun:** Sunucu kapalıyken bile `serverSyncReady`'in `.finally()`'ı ile (`App.tsx` ~satır 504) debounced push çalışır; ağ hatasında (`status 0`) tam `DataDocument` localStorage'a kuyruklanır. Uygulama limiti 25 MiB (`limits.ts`) iken tarayıcı localStorage kotası tipik olarak 5–10 MiB'dir. Kota aşılırsa yazma **sessizce** başarısız olur, arayüz "kuyrukta" gösterir, sekme kapanınca değişiklikler kaybolur. (Karşıt olarak `cinetrack-core.ts` `savePersistentTasteMap` aynı senaryoda compaction + in-memory fallback yapıyor — kuyrukta bu disiplin yok.)
- **Çözüm:**
  1. `enqueueOfflineSyncSnapshot` dönüş tipini `{ entry, persisted: boolean }` yapın; `setItem` başarısızlığında `persisted: false` döndürün.
  2. `useOfflineSync.syncDocument` persisted=false ise kullanıcıya açık uyarı gösterin: "Değişiklikler yalnızca bu sekmede duruyor — sunucu dönene kadar sekmeyi kapatmayın."
  3. Orta vade: kuyruk depolamasını IndexedDB'ye taşıyın (`relationship-cache.ts`'te zaten benzer bir kalıp var) veya payload'u kompakt forma indirin (özet + items).
  4. Regresyon testi: `enqueueOfflineSyncSnapshot`'ı mocked-quota localStorage ile çağırıp `persisted === false` ve UI uyarısını doğrulayın.

---

2. P1 — Yüksek

BUG-03 · `node server.ts` sessizce Node sürümüne bağlı (engines kilidi yok)

- **Kanıt:** `package.json` → `"start": "node server.ts"`, `engines` alanı yok. Kod, Node'un yerel TypeScript type-stripping'ine dayanır (Node 22.18+/23.6+ varsayılan; eski sürümlerde derleme hatasıyla çöker). CI `node-version: '22'` kullanır — bu bugün ≥22.18'e çözüldüğü için yeşil görünüyor, ancak yerelde Node 20 veya 22.6–22.17 kullanan biri için `npm start` doğrudan syntax error verir. `tsx` ile `dev` çalışır ama prod için `tsx` devDependency olduğu için `npm prune --omit=dev` sonrası yoktur.
- **Çözüm:**
  1. `package.json`'a ekleyin: `"engines": { "node": ">=22.18.0" }` ve `start.bat` içinde sürüm denetimi (baştaki `where node` bloğunun yanına `node -e "const [ma,mi]=process.versions.node.split('.').map(Number); if(ma<22||(ma===22&&mi<18)){console.error('Node >= 22.18 gerekir');process.exit(1)}"`).
  2. `tsconfig.json`'a `"erasableSyntaxOnly": true` ekleyin (TS 5.8+): enum/namespace/constructor param-prop gelecekte eklenirse tsc anında yakalar; Node type-stripping uyumluluğu kalıcı garantiye bağlanır. (Kod şu an incelendi: erasable-olmayan sözdizimi yok, yani bu güvenli.)
  3. README kurulum bölümüne "Node.js ≥ 22.18" şartını yazın.
- **Kabul kriteri:** Node 22.17 Docker imajında `npm start` açık hata verir (engines), CI lint'i `erasableSyntaxOnly` ile geçer.

BUG-04 · Senkron (bloklayan) dosya I/O — request handler içinde

- **Kanıt:** `src/server/storage.ts` (`readFileSync`/`writeFileSync`/`copyFileSync`), `src/server/app.ts` (`readFileSync` yedek indirmede, satır ~830), `excel-profile-backup.ts` (`writeFileSync` ~satır 2778). Ana veri dosyası 25 MiB'e kadar büyüyebilir.
- **Sorun:** 25 MiB JSON'un senkron parse+stringify+write+fsync'i event loop'u yüzlerce ms–sn bloklar; bu sürede TMDB proxy, diğer istemciler ve PWA istekleri donar. Tek kullanıcılı kurulumda küçük, ama 5 dk'lık otomatik sync + debounced istemci push'u üst üste bindiğinde hissedilir gecikmeler üretir.
- **Çözüm (kademeli):**
  1. Kısa vade: `readJsonFileWithRecovery` ve `writeJsonFileAtomic`'ı `fs/promises` tabanlı asenkron varyantlara geçirin; `FileWriteSerializer` zaten sıraya alıyor, bu taşıma güvenli.
  2. Yedek indirme endpoint'inde `readFileSync` yerine `createReadStream` + `res.stream` kullanın.
  3. Excel dışa aktarımında `writeFileSync(fullPath, buf)` → `await fs.promises.writeFile(...)`.
- **Kabul kriteri:** 25 MiB veri ile yük altında `/api/health` p99 < 50 ms kalır (basit k6/autocannon ölçümü).

BUG-05 · Rate limiter `X-Forwarded-For`'a güveniyor + varsayılan kapalı

- **Kanıt:** `src/server/security.ts` → `clientIp = forwarded.split(',')[0] || ...`. `createTmdbRateLimitMiddleware` `maxReq <= 0` ise no-op; env/opt belirtilmedikçe devre dışı.
- **Sorun:** (a) Proxy arkasında değilken `X-Forwarded-For` istemci tarafından uydurulabilir → limit her istekte "farklı IP" ile bypass edilir. (b) Açıkta çalışırken (BUG-01 düzeltilse bile) TMDB proxy'si hiçbir rate limite tabi olmaz; sunucudaki TMDB API anahtarı kötüye kullanım vektörüdür.
- **Çözüm:** 1) Uzaktan erişim açıkken (`host !== loopback`) varsayılan rate limit'i etkinleştirin (ör. 60 istek/dk). 2) `X-Forwarded-For`'u yalnızca açık `CINETRACK_TRUST_PROXY=true` bayrağı varsa kullanın; aksi halde `req.socket.remoteAddress`. 3) `app.set('trust proxy', ...)` ayarını belgeleyin.

BUG-06 · Repoya commit'lenmiş build artifact'ları ve ölü metadata

- **Kanıt:** `dev-dist/sw.js` + `dev-dist/workbox-*.js` (vite-plugin-pwa `devOptions.enabled: true` çıktısı — resmi öneri bu klasörün gitignore edilmesi); `.aistudio/` (AI Studio kalıntısı); `metadata.json` → `"MAJOR_CAPABILITY_SERVER_SIDE_GEMINI_API"` (kodda hiçbir Gemini/sunucu-tarafı LLM entegrasyonu yok — grep ile doğrulandı).
- **Sorun:** Depo şişkinliği, gizli tutulması gerekmeyen ama alakasız iç araç kalıntıları, yanlış yönlendiren yetenek bildirimi.
- **Çözüm:** `.gitignore`'a `dev-dist/` ve `.aistudio/` ekleyip repo history'den kaldırın (`git rm -r --cached dev-dist .aistudio`); `metadata.json`'ı silin ya da gerçek yetenekleriyle güncelleyin.

---

3. P2 — Orta / Düşük

BUG-07 · Çevrimdışı kuyrukta 409 çakışmasında kuyruk siliniyor

- **Kanıt:** `src/hooks/useOfflineSync.ts` `flushQueue`: `res.status === 409` → `clearOfflineSyncSnapshot()` sonra `onConflict`.

- **Sorun:** Yerel doküman artık yalnızca React state'inde yaşar. Çakışma banner'ı açıkken sekme kapanırsa, sunucu versiyonuna rağmen yerel değişiklik kalıcı olarak kaybolur (banner yalnızca `serverConflict` state'ini tutuyor; payload korunmuyor).
- **Çözüm:** Çakışma çözülene kadar snapshot'ı kuyrukta tutun; "Yereli koru" başarılı push sonrası, "Sunucuyu kullan" `applyDataDocumentToState` sonrası temizlesin. Ek olarak payload'u `serverConflict` state'ine gömün.

BUG-08 · `resolveExportDocument` istemci snapshot alanlarını kontrolsüz yayıyor

- **Kanıt:** `src/server/app.ts` ~satır 135: `const mergedProfile: Profile = { ...existing, ...snap, ... }`.
- **Sorun:** İstemciden gelen bilinmeyen/rastgele alanlar (`snap`) profile girer; `normalizeDataDocument` sonrasında büyük olasılıkla temizlenir ama sözleşme garantisi yok ve bellekte gereksiz alan birikir.
- **Çözüm:** `snap`'tan yalnızca whitelist'li alanları alın (`name`, `createdAt`, `isDemo`); spread'i kaldırın. Birim testi: bilinmeyen alan içeren snapshot gönderin, kaydedilen profile'da o alanın olmadığını doğrulayın.

BUG-09 · Testler tip denetimi ve lint kapsamı dışında

- **Kanıt:** `tsconfig.json` `include: ["src", "server.ts", "vite.config.ts"]`; `eslint.config.js` `ignores: [... 'tests/**']`.
- **Sorun:** 6 test dosyası (~600 KB) tsc ve eslint'ten geçmez; testlerdeki tip hataları yalnızca çalışma zamanında ortaya çıkar.
- **Çözüm:** Ayrı bir `tsconfig.tests.json` ile `tsc --noEmit -p tsconfig.tests.json` script'i ekleyin; eslint ignores'tan `tests/**`'i çıkarıp (en azından `recommended`) dahil edin. Testler zaten `node:test` + `assert/strict` kalitesinde — buna değiyor.

BUG-10 · i18n yarım implemented (ölü sözlük)

- **Kanıt:** `src/i18n/index.ts` — `setLocale` hiçbir yerden çağrılmıyor (grep: 0 sonuç); `en` sözlüğü ölü. Bileşenlerde yüzlerce hardcoded Türkçe metin.
- **Çözüm:** İkisinden biri: (a) dil seçici ekleyip bileşen metinlerini sözlüğe taşıyın (büyük iş), ya da (b) dürüst davranıp i18n katmanını kaldırın, README'ye "yalnızca TR" yazın. Mevcut ara durum en kötü seçenek: her iki dünyanın bakım maliyeti.

BUG-11 · `any` yoğunluğu ve devasa monolit dosyalar (sürdürülebilirlik)

- **Kanıt:** `cinetrack-core.ts` 5.560 satır / 126+ `any`; `App.tsx` 2.860 satır; `ProfileModal.tsx` 77 KB; `github-bidirectional-sync.ts` 4.489 satır; `tests/core.test.mjs` 198 KB. ESLint'te `no-explicit-any: off`.
- **Sorun:** Merge çakışmaları, code review kalitesi ve yeni katkıda bulunma hızlı düşer; çekirdek dosya hem istemci hem sunucu tarafından import edildiği için her düzenleme iki bundle'ı büyütür.
- **Çözüm (kademeli, davranışı değiştirmeden):**
  1. `cinetrack-core.ts`'i modüllere bölün: `types.ts`, `keys` (zaten var), `normalize.ts`, `taste-profile.ts`, `recommendation.ts`, `taste-map-storage.ts`, `backup-text.ts` (projede zaten `evaluation.ts`, `exporters.ts` gibi parçalar var — aynı yönde devam edin).
  2. `App.tsx`'i: `hooks/useProfiles.ts`, `hooks/useRecommendations.ts`, `hooks/useCatalog.ts`, `hooks/useReminders.ts` şeklinde custom hook'lara bölün; JSX'i sayfa bileşenlerine taşıyın.

3. `no-explicit-any`'yi `warn`'e alın, yeni PR'lerde `error`'e yükseltin (yeni kod için `tsc` guard'ı).

- **Not:** Bu, tek seferlik büyük refactor değil; "her dokunduğunda dosyayı böl" politikası + ölçüt: hiçbir dosya 1.000 satırı geçmesin.

BUG-12 · Güvenlik başlıkları ve güvenlik odaklı küçük eksikler

- `helmet` benzeri başlık seti yok (`X-Frame-Options`/CSP yok; index.html inline SVG'li SPA). Sertifikasız localhost kullanımında risk düşük ama eklenmesi ucuz: `res.setHeader('X-Frame-Options','DENY')`, `Referrer-Policy`, temel CSP (`default-src 'self'; img-src https://image.tmdb.org; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src https://fonts.gstatic.com`).
- `GET /api/sync/status` token guard'ı yok: uzak repo adı/branş gibi hafif bilgi sızıntısı (BUG-01 düzelince ikincil kalır; yine de guard ekleyin).
- `parseIfMatchRevision`: `If-Match` başlığı yoksa revizyon kontrolü atlanır (last-write-wins). İstemci her zaman gönderiyor, ancak "revizyon zorunluluğu" sunucuda da istenebilir: `PUT /api/data`'da `If-Match` yoksa ve mevcut `revision > 0` ise 428 (`Precondition Required`) dönün — tasarımın kendi güvencesini sunucu tarafına da kilitleyip veri kaybını tamamen engeller.

BUG-13 · Dokümantasyon/UX küçükleri

- `.env.example` eksik anahtarlar: `CINETRACK_TOKEN`, `PORT`, `CINETRACK_TMDB_RATE_LIMIT` (kod destekliyor, örnek dosyada yok).
- `helpers.ts` `calculateItemWatchMinutes`: film için varsayılan 110 dk, dizi için sezonda 10 bölüm tahmini — istatistikler yanıltıcı olabilir; sabitlere koyup README/İstatistik tooltip'inde "tahmini" ibaresi ekleyin.
- `checkReleaseReminders` effect'i `[checkReleaseReminders]`'e bağlı olduğu için her preferences/savedItems değişiminde interval yeniden kurulur; hatırlatma penceresi (3 gün) nadiren atlanabilir. Ref'lerle sadeleştirin.
- Dependeabot/Renovate yapılandırması yok; `npm audit --production`'ı CI'a ekleyin.
- LICENSE MIT olduğu halde README'de lisans bölümü yok.

---

4. Doğrulanan Güçlü Yönler (korunmalı)

- **Atomik kalıcılık zinciri:** `writeJsonFileAtomic` (temp + fsync + rename + validateParsed + yedek kurtarma + karantina) ve `FileWriteSerializer` ile dosya başına yazma kuyruğu.
- **Çakışma güvenliği:** ETag `"rev-N"` / `If-Match` iyimser kilidi + `sudden_item_drop` toplu silme koruması + istemcide `ConflictBanner` akışı.
- **GitHub sync disiplini:** sınıflandırılmış hatalar (auth/rate_limit/conflict), okuma-geri SHA-256 doğrulaması, açık repoya kişisel veri yazma çift onayı (`public-consent`), `redactSecrets` ile log sızıntısı maskeleme.
- **TMDB proxy:** katı path/query whitelist (regex), parametre doğrulama, in-flight dedup + TTL'li önbellek + stale-cache fallback + demo modu.
- **Test disiplini:** ~600 KB davranışsal test (sync, kalıcı depo, Excel yedeği, çekirdek) + CI'da `--omit=dev` sonrası üretim smoke testi — nadir görülür bir pratik.
- **Erişilebilirlik:** `useDialogAccessibility` (focus trap, ESC, odak iadesi), `aria-live` bölgeleri, klavye kısayolları (n, /).

regex doğrulaması.

- **Kabul testi:** Aşırı büyük sahte `Content-Length` → 502/413; `language=<script>` → 400.

EXT-09 · Yapılandırma önceliği değişkenler arasında tutarsız — token gölgeleme (P1 — 401 hatasının olası kök nedeni)

- **Kaynak:** ChatGPT FINDING-02/FINDING-03, Perplexity CT-004 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt:** `server.ts` satır ~43–59: token için önce `process.env.CINETRACK_GITHUB_TOKEN` (eski ad!), sonra `CINETRACK_GITHUB_PAT`; her ikisi de **.env.local/.env dosya değerlerinden ÖNCE** gelir. Satır ~63–88: `CINETRACK_DATA_REPO_IS_PUBLIC` ve `CINETRACK_ALLOW_PUBLIC_PERSONAL_SYNC` için ise tam tersi — **dosya değeri process.env'i ezer**. Yani: hosting platformunda güncellenen PAT, repodaki eski `.env` içindeki değer tarafından geçersiz kılınabilir; buna karşılık eski `CINETRACK_GITHUB_TOKEN` ortamda kalıysa yeni PAT'i gölgeleyebilir. Kullanıcının yaşadığı **401 Bad credentials** döngüsü bu üç ihtimalden biriyle uyumludur.
- **Çözüm:** Tek bir `resolveConfig()` fonksiyonu, tüm değişkenler için **tek öncelik kuralı:** **`process.env`** > **`.env.local`** > **`.env`** > **güvenli varsayılan**. Birincil token adı `CINETRACK_GITHUB_PAT` olarak belgelenir; `CINETRACK_GITHUB_TOKEN` desteklenecekse her iki değişken de dolu ve farklıysa startup'ta (değeri göstermeden) uyarı. Tanılama ekranı seçilen kaynağı gösterir: `env:CINETRACK_GITHUB_PAT` / `file:.env.local` vb. 401/403/404 hataları ayrı mesajlarla ayrıştırılır.
- **Kabul testi:** (a) process.env PAT + .env eski token → process.env kazanır; (b) her iki token de tanımlı → birincil seçilir ve uyarı basılır; (c) token değeri hiçbir log/yanıt/yedekte görünmez.

EXT-10 · Public repoya TMDB katalog dosyaları yazılabiliyor (P1 — Lisans/uyum)

- **Kaynak:** ChatGPT FINDING-04 · **Durum:** Kod-dokümantasyon çelişkisi olarak doğrulandı.
- **Kanıt:** README, TMDB verisinin herkese açık yeniden dağıtılamayacağını ve uzak eşitlemenin **özel** depo için kullanılmasını söylüyor; ancak `github-bidirectional-sync.ts` ~satır 59–67 envanterde film/dizi kataloglarını senkronize edilebilir dosyalar olarak sınıflandırıyor ve `syncToGitHub()` katalog dosyalarını kişisel dosyalardan önce planlıyor; public guard öncelikle **kişisel** dosyalara uygulanıyor. Profil verisinin public olması için verilen onay, TMDB metaverisinin toplu yeniden dağıtımı izni değildir.
- **Çözüm:** 1) Depo görünürlüğünü yalnızca env'den değil GitHub API'den doğrula (`GET /repos/{owner}/{repo}` → `private` alanı); 2) depo public ise katalog dosyalarının (`movies.json`, `tv.json`, katalog `manifest.json`) yüklenmesini **varsayılan olarak reddet** — bu kural kişisel veri onayından bağımsız; 3) kullanıcı katalog paylaşımını isterse bunun ayrı, adlandırılmış bir onay bayrağı olmalı (`CINETRACK_ALLOW_PUBLIC_CATALOG_SYNC`) ve UI'da lisans uyarısıyla birlikte gösterilmeli.
- **Kabul testı:** Public repo + kişisel onay var → katalog dosyaları plan dışı kalır, kişisel dosyalar gider; private repo → mevcut davranış korunur.

EXT-11 · İki yönlü eşitlemede silinen kayıtlar geri gelebiliyor (P2 — Veri bütünlüğü)

- **Kaynak:** ChatGPT FINDING-08 · **Durum:** Kaynak kodda doğrulandı (bilinçli no-deletion birleştirme).
- **Kanıt/Problem:** Birleştirme politikası bilinçli olarak hiçbir şeyi silmiyor (veri kaybı koruması — doğru başlangıç). Ancak kullanıcı bir kaydı **bilerek** kaldırdıysa ve o kayıt uzak depoda kaldıysa, bir sonraki eşitlemede geri gelir; "sil" eyleminin senkron sistemde kalıcı bir karşılığı yok.
- **Çözüm:** Sessiz fiziksel silme yerine **tombstone (soft-delete)** kaydı: silinen öğenin anahtarı + silme zamanı profilde `deleted_keys` gibi bir alana yazılır; birleştirme tombstone'u görürse o anahtarı uzaktan geri

almaz; tombstone'un kendisi yine düşük olasılıklı uzak yazma ile korunur. Tombstone'lar 30+ gün sonra toplanır.

- **Kabul testi:** Yerelde silinen kayıt, uzakta duruyken iki yönlü eşitleme sonrası **geri gelmez**; uzaktan gelen gerçek yeni kayıtlar etkilenmez.

EXT-12 · `resolveExportDocument` boş snapshot ile bilinçli temizlemeyi ayırt edemiyor (P2)

- **Kaynak:** Kimi MER-001 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt/Problem:** İstemci snapshot'ındaki bir liste alanı boşsa (örn. `disliked: []`), sunucu bunu "alan gönderilmedi" varsayımıyla mevcut veriyi koruyor. Kullanıcı listedeki **tüm** kayıtları bilerek temizlediyse bu silme sunucuya ulaşmaz — sessizce eski kayıtlar geri döner. (EXT-11 ile aynı ailenin istemci/sunucu tarafı.)
- **Çözüm:** Alan-seviyesinde varlık semantiği: alan **yoksa** → korunur; alan **varsa ve boşsa** → bilinçli temizleme kabul edilir (tek kayıtlık silmelerde zaten çalışıyor; tam liste temizleme test edilmeli). Davranış birim testiyle sabitlenip dokümante edilir; kullanıcıdan gelen `null` ile eksik alan birbirine karıştırılmaz.
- **Kabul testi:** Boş `disliked: []` snapshot'ı → sunucuda da boş; alan gönderilmemiş → sunucu değeri korunur.

EXT-13 · .env parser satır bazlı basit çözümleme (P2)

- **Kaynak:** Perplexity CT-009 · **Durum:** Kaynak kodda doğrulandı.
- **Kanıt/Problem:** `loadLocalEnv` tarzı çözümleme tırnak/escape işleme, `export` öneki, çok satırlı değerler ve `#` yorumlarını içeren standart dotenv formatını tam desteklemiyor. Elle düzenlenmiş bir `.env`'deki sembolik hatalar sessizce yanlış değere dönüşür (EXT-09 ile birleşince: yanlış token/flag okuma).
- **Çözüm:** Standart `dotenv` paketine geçilmesi en temiz çözüm (prod bağımlılığı küçük ve güvenli) ya da mevcut parser'a tırnak-strip + `export` öneki + satır içi yorum toleransı + bozuk satır uyarısı eklenir. EXT-09'daki `resolveConfig()` ile aynı yerde uygulanır.
- **Kabul testi:** `TOKEN="abc def"`, `export X=1`, `# yorum` içeren .env → değerler dotenv referans davranışıyla aynı çözümlenir.

EXT-14 · Düşük güvenli UX/istekci bulguları (P3 — doğrulanabilir, düşük risk)

- **Kaynak:** Gemini · **Durum:** Kısmen doğrulanabilir; çalışma zamanı testi gerekli.
- **İçerik:** (a) Öneri havuzu tükendiğinde kullanıcıya anlamlı "kaynak yok" mesajı/fallback akışı; (b) `hideSavedItems` gibi görünürlük tercihlerinin oturmlar arası kalıcılığı; (c) Küçük ekranlarda CSS `clamp()` ile başlık ölçekleme. Üçü de davranışsal/istekci iyileştirmesi olarak **ekran/kayıt testiyle** doğrulanmalı; güvenlik/veri bütünlüğü etkileri yok. Uygulama öncesi doğrulama: ilgili state'in `localStorage`'a yazılıp yazılmadığı ve havuz-tükenmesi senaryosunun elle tetiklenmesi.
- **Not:** Bu maddeler spec'in geri kalanından farklı olarak **hipotez** niteliğindedir; kodlama ajanı uygularken önce varlığını doğrulamalı, yoksa yeni iş olarak değil istek olarak değerlendirmelidir.

6.3 Çürütülen veya doğrulanamayan iddialar (kodlama ajanı bunları takip etmesin)

İddia	Kaynak	Doğrulama sonucu
"MediaCard'ta lazy loading / `decoding="async"` / `fetchPriority` eksik"	DeepSeek	**YANLIŞ.** `MediaCard.tsx` satır ~174–180: `loading={_eager ? 'eager' : 'lazy'}`, `decoding="async"`, `fetchPriority` mevcut. Düzeltme gerekmez.
	DeepSeek	

İddia	Kaynak	Doğrulama sonucu
"App.tsx'te `useMemo` hiç kullanılmıyor"		**Kısmen yanlış.** 2 kullanım mevcut (az, sıfır değil). "Daha fazla useMemo" bir iyileştirme önerisidir, hata değildir; BUG-11 refaktörü içinde değerlendirilir.
"Poster indirmede tek görsel boyut sınırı yok"	(ChatGPT FINDING-10 bağlamı)	**Kısmen yanlış.** Tek görsel için 5 MiB sınır + minimum boyut kontrolü var; **sınırsız büyüyen önbellek** (EXT-03) ise doğrudur.
Öneri havuzu tükenmesi fallback'i, CSS clamp	Gemini	Doğrulanamadı — davranışsal test gerektirir (EXT-14'te hipotez olarak işaretlendi).

---

7. Referanslar

- Node.js yerel TypeScript (type stripping, 22.18+ varsayılan, erasable-sözdizimi sınırı): nodejs.org/learn/typescript/run-natively
- vite-plugin-pwa `dev-dist` klasörünün gitignore edilmesi önerisi: progressivewebapps.com/tooling/vite-pwa